Security Foundations Assessment 01

Name: Gude Rajesh
Batch: 1

Task A Student account protection

A1 and A2 Risk assessment

Risk	Asset	CIA impact	Control	Limitation
Weak password reused across services	Email and portal accounts	Confidentiality: one exposed password can reveal messages and records. Integrity: another person may alter work.	Replace it with a different long password for each service; use a password manager to avoid reuse.	A unique password can still be stolen by a deceptive login page.
MFA requests accepted without checking	Authenticated account sessions	Confidentiality and integrity: approving someone else's request can grant access to private data and account functions.	Reject any prompt not linked to a login Mira has just started, and report it.	This depends on recognising the request; an existing stolen session may require revocation.
Security updates repeatedly delayed	Laptop software and stored information	Confidentiality, integrity and availability: an unfixed flaw may allow data theft, unwanted changes or disruption.	Set automatic updates and schedule the restart needed to finish installation.	Patching cannot prevent every attack or fix insecure account habits.
Project exists on one laptop only	Project files	Availability: theft, damage or a failed drive could remove access to all work.	Maintain a separate versioned backup and periodically restore a file as a check.	A backup may be outdated or unusable unless it is checked.
Friend works inside Mira's session	Personal files and signed-in services	Confidentiality: the friend can read private content. Integrity: changes may be recorded under Mira's identity.	Give the friend a separate standard account and lock Mira's account before handing over the laptop.	It will not protect an account whose password is shared or whose session is left open.

A2 First three actions

1. Reject unexpected MFA requests immediately. This closes the most immediate opportunity for another person to obtain approval. If any request has already been accepted, ask official IT to review and revoke affected sessions.
2. Replace the weak reused password on email and the portal. Secure email first because it may receive account-recovery links. This reduces both easy guessing and the spread of access from one service to another.
3. Apply the pending security updates and restart the laptop. Otherwise, account improvements may leave the device exposed to known software flaws. Create the separate friend account and the project backup promptly afterward; neither should be treated as optional.

A3 Authentication and authorisation

Authentication answers "Is this really Mira?" Her portal checks her login credentials and MFA before establishing a session. Authorisation answers "What may Mira do?" As a student, she can submit her assignment and read her own results. She should not be able to award marks, view another student's private record or manage users. The portal must enforce these permissions even after a successful login.

Task B Scholarship message assessment

B1 Warning signs in the supplied message

Relevant phrase	Reason for concern
"campus-awards.example"	This is a different domain from campus.example, the college's normal domain. The extra word does not establish an official relationship.

Relevant phrase	Reason for concern
“help@personal-awards.example”	Replies go to a separate domain from the claimed scholarship sender, so the reply destination needs independent confirmation.
“FINAL WARNING” and “20 minutes”	The threat and short deadline discourage careful checking and encourage an impulsive response.
“college password and OTP”	A request for both authentication secrets could enable access to a student account rather than scholarship verification.
“photo of your identity card”	The message requests sensitive identifying information without a verified official process or confirmed recipient.

B2 Independent verification

1. Keep the message but avoid the link, attachments and reply address. Do not upload identification or provide login secrets.
2. Open the college portal from a trusted bookmark or use a known official college directory to find the scholarship office. Obtain the contact independently of this message.
3. Ask the office to confirm the award, the deadline and the requested process. The instruction not to contact the office is itself a reason to check independently.
4. Forward the evidence through the college’s approved reporting route if the request cannot be confirmed. HTTPS indicates an encrypted connection to a domain; it does not certify that the college runs that domain. A display name such as Scholarship Desk can also be copied.

B3 If the password and OTP were entered

1. Stop using the suspicious page. Contact official IT urgently and explain that the password and OTP were disclosed, including the approximate time. Do not include the actual secrets.
2. On a trusted device, independently open the genuine service and reset the exposed password. Replace the same password on any other affected accounts, particularly the linked email account.
3. Have IT terminate existing sessions and check recovery contacts and registered MFA methods. An OTP may expire while a session created using it remains active.
4. Preserve the original message and the time of the interaction. Review login history, email forwarding, profile settings and submitted work for unfamiliar activity. Continue monitoring alerts and report any changes to IT.

B4 Limit of the evidence

I cannot determine whether the college authorised the scholarship campaign from the message text alone. Confirmation from the independently contacted scholarship office and official campaign records would help resolve that question. Full message headers could provide additional delivery evidence, but would not replace official confirmation.

Task C Sign in investigation

The following timeline uses IST on 18 October 2026. The supplied IP addresses are reserved examples and cannot be used to identify an individual.

C1 Four point timeline

Period	Observation	Interpretation
09:00 and 09:01	Successful password authentication followed by approved MFA from the usual classroom egress, 192.0.2.10.	This forms a baseline consistent with the student’s account of an earlier login. It does not independently prove who operated the device.
10:14 to 10:16	Two failed password events, then a successful password event from 198.51.100.23.	Valid credentials appear to have been accepted after failures. The records do not reveal whether they were guessed, stolen or entered legitimately.

Period	Observation	Interpretation
10:17 and 10:18	MFA was denied and then approved. The student says the approval was intended to stop repeated requests and denies logging in after 09:05.	The approval appears unsolicited according to the user, making MFA fatigue a plausible explanation.
10:20	A session was created from 198.51.100.23.	The sequence raises concern about unwanted access. Application audit records are needed to establish what the session did.

C2 Explanation and checks

Likely explanation: another party had valid credentials and relied on the student accepting an unwanted MFA prompt. The student's statement makes this more concerning than a simple network change. However, the logs do not establish the credential source or identify the operator.

Alternative: a legitimate device had a delayed or background login through another network, and the student misunderstood its prompts. That possibility requires evidence rather than acceptance at face value.

Check 1. Correlate authentication transaction IDs, MFA challenge IDs and the created session. Compare device identifiers and browser details with the student's recognised devices to check whether the approval completed that login.
Check 2. Review device history and portal audit activity with the student. A known device and expected activity could support the alternative; an unrecognised device and unexplained account changes would increase concern about compromise.

C3 Three prioritised response actions

1. Protect access now. Authorised IT should revoke active sessions and tokens, temporarily restrict access if needed, and arrange a secure password reset. Preserve key live session details in parallel without delaying containment.
2. Preserve and establish scope. Retain the original sign-in, MFA and application logs, noting timestamps and collection details. Store controlled copies, record the student's statement and check for data access or account changes.
3. Recover safely. Verify recovery details, remove unfamiliar authentication methods and restore access after checking the account. Explain how to reject and report unexpected prompts, consider phishing-resistant MFA and monitor further sign-ins.

C4 Incident summary

The account student07 recorded password success, MFA approval and session creation between 10:16 and 10:20 IST, following two password failures and an MFA denial. The student reports no login after 09:05 and says the later approval was made to stop repeated prompts. These facts support suspected account misuse through unwanted MFA approval. They do not prove the identity of an attacker or the password's origin. The priority is to revoke sessions and secure the account while retaining evidence. IT should next correlate the authentication flow with device records and application activity.

Task D Evaluation of AI advice

D1 Five errors and corrections

Claim or instruction	Correction and supporting reason
HTTPS makes the email safe.	An encrypted connection does not establish the sender's legitimacy. In Task B, domain differences and demands for secrets still require verification. [1]
The IP proves who stole the password.	The log shows a source address and authentication results, not a named person or credential-theft event. The assessment explicitly warns that a different IP alone is not proof. [1]
MFA stops every compromise.	Approval-based MFA can be undermined by unwanted approvals. The student's 10:18 statement provides a specific reason not to make an absolute claim. [1]

Claim or instruction	Correction and supporting reason
Suspicious logs should be deleted.	Retain the logs so authorised investigators can reconstruct events and assess account activity. Deletion would remove the supplied evidence needed for triage. [1]
Support should receive the password.	Support should use secure recovery procedures and logs, not collect the student's password. The assessment forbids requesting authentication secrets. [1]

D2 Prompt for a safer AI analysis

Act as a reviewer of the EWB fictional assessment evidence. Use only the supplied scholarship message, synthetic logs and student statement. Produce a warning-sign analysis, a four-point timeline and prioritised response recommendations for authorised IT. Label direct observations separately from inferences. Include an alternative explanation, missing evidence and your uncertainty. Do not claim an IP identifies a person, invent events, open the sample URLs or recommend live testing. Never request passwords, OTPs, identity documents or real student information. Preserve relevant evidence and explain how every major conclusion follows from the supplied material.

D3 Corrected security advice

Do not trust the scholarship request solely because its link begins with HTTPS. The unfamiliar domains, urgency and demand for authentication secrets justify checking it through a college contact obtained independently. If credentials were entered, use the genuine portal to reset them and ask official IT to revoke sessions. Never provide a password or OTP to support. The later sign-in sequence is concerning because the student reports approving an unsolicited prompt before a session appeared. Treat this as suspected compromise, not proven attribution to a person behind an IP address. Preserve the logs and user statement, correlate the MFA approval with the session, and inspect account activity for changes. After containment, verify recovery settings and MFA methods, then monitor the account for further unexpected requests.

D4 AI assistance declaration

ChatGPT was used to develop this alternative report, organise the answers and format the document. The content is AI-assisted and is based on the fictional evidence provided in the assessment. No real accounts were tested and no passwords or OTPs were supplied.

References and supporting notes

References

[1] EWB Courses. Assessment 01: Security foundations. Issued 18 October 2026, pages 1–4. Source of all scenarios, message quotations, sign-in events and the AI output reviewed in this report.

[2] Cybersecurity and Infrastructure Security Agency. Secure Our World. Account and phishing reference recommended in the assessment.
https://www.cisa.gov/secure-our-world

[3] National Institute of Standards and Technology. Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile. NIST AI 600-1, July 2024, section 2.2, Confabulation.
https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.600-1.pdf

D4 Evidence note 1

The account log contains a successful password event, an MFA approval and a later session. Combined with the student's denial of a later login, this supports urgent investigation. It does not prove password theft, successful data extraction or a particular person's identity. This distinction supports the cautious conclusions in Tasks C and D. [1]

D4 Reference note 2

NIST describes confabulation as confidently stated false or erroneous AI content. This is why the fictional answer's conclusions need checking against the actual evidence. Its certainty about identity and complete MFA protection is unsupported, while its instructions to delete logs and share a password conflict with the assessment's evidence-preservation and secrecy requirements. [1, 3]